The Procedural Semantics Gap in ATT&CK-in-STIX: A Measurement-Driven Analysis for APT Emulation

Ágney Lopes Roth Ferraz*
Aeronautics Institute of Technology
São José dos Campos, SP, Brazil
roth@ita.br

Sidnei Barbieri*†
Carnegie Mellon University
Pittsburgh, PA, USA
sbarbier@andrew.cmu.edu

Lourenço Alves Pereira Júnior
Aeronautics Institute of Technology
São José dos Campos, SP, Brazil
ljr@ita.br

Abstract

Public ATT&CK content serialized in Structured Threat Information Expression (STIX) has become a global reference for describing adversary behavior. Yet ATT&CK was designed as a descriptive knowledge base, not as a procedural model. We therefore ask whether ATT&CK-in-STIX contains enough behavioral detail to support multi-stage adversary emulation. Measuring the ATT&CK Enterprise bundle, we find that campaign objects encode fragmented behavioral slices: only 43.0% of techniques appear in at least one campaign, and neither clustering nor Longest Common Subsequence (LCS)-based probes reveal reusable structure. Intrusion sets cover more of the technique space, but still omit ordering, preconditions, and environmental assumptions. Public CTI therefore describes *what* adversaries do, but not enough of *how* to execute those behaviors automatically.

To test how far explicit translation can bridge that gap, we define a three-stage methodology and instantiate it in the MITRE Caldera framework. Case studies of *ShadowRay* and *Soft Cell* show that structured CTI can support multi-step adversary enactment only after missing parameters and assumptions are supplied and validated. We also audit the eight curated adversaries packaged in the legacy Docker artifact and find that all eight workflows reach explicit end markers within the observed window and leave no residual non-zero links once execution settles. Together, these results turn a familiar complaint about CTI incompleteness into a reproducible boundary between behavioral signal already encoded in public CTI and the procedure that still must be supplied explicitly before execution.

CCS Concepts

• **Security and privacy → Intrusion/anomaly detection and malware mitigation**; *Systems security*; Network security.

Keywords

cyber threat intelligence, STIX, MITRE ATT&CK, system under test, adversary emulation, structured CTI

ACM Reference Format:
Ágney Lopes Roth Ferraz, Sidnei Barbieri, and Lourenço Alves Pereira Júnior. 2026. The Procedural Semantics Gap in ATT&CK-in-STIX: A Measurement-Driven Analysis for APT Emulation. In *Proceedings of 2026 ACM SIGSAC Conference on Computer and Communications Security (ACM CCS '26).* ACM, New York, NY, USA, 16 pages.

*These authors contributed equally to this work.
†Also with Aeronautics Institute of Technology.

ACM CCS '26, The Hague, The Netherlands
2026.

1 Introduction

Advanced Persistent Threats (APTs) unfold as multi-stage campaigns that may span multiple hosts, adapt to the target environment, and frequently rely on "living-off-the-land" techniques that blend with legitimate activity [4]. Their distributed low-signal activities [44] and prolonged dwell times [29] make end-to-end reconstruction complex in Security Operations Centers (SOCs) [9, 16, 27].

Provenance-based detection and learning-driven approaches show why. Reconstructing multi-step behaviors induces dependency explosion and produces large provenance graphs with multiple roots [8, 19, 20, 42]. They also show that short or synthetic traces fail to represent characteristic APT dependencies [18, 29, 44].

Cyber Threat Intelligence (CTI) provides structured accounts of adversary tactics and techniques. Public feeds exhibit heterogeneous formats, uneven granularity, and inconsistent field usage [22, 41]. However, extracting actionable information from narrative reports requires substantial manual effort [35], and most CTI sources lack the procedural context and environmental constraints necessary for reproducible multi-host emulation [41]. Analyses of intrusion-detection rules additionally show rapid turnover, skewed alert distributions, and weak links between rules, alerts, and incidents [43]. As a result, CTI is used for mapping and coverage but rarely as a direct source of executable adversary actions.

The MITRE ATT&CK framework provides a widely adopted taxonomy of tactics and techniques, disseminated as STIX bundles consumed by defensive platforms [30, 40, 45]. These bundles combine campaigns, intrusion sets, malware, tools, and relationships, but campaign and intrusion-set entries rarely encode temporal or causal information. Execution order, prerequisites, and environmental assumptions typically appear only in free text [30, 35, 41]. Prior work either extracts partial behaviors from textual intelligence without producing executable actions [7, 35, 48] or reconstructs long-duration campaigns from telemetry [8, 42, 44]. The question of how far ATT&CK-in-STIX can support APT emulation therefore remains open.

We intentionally study the Enterprise bundle because, among the public STIX sources we parsed, it preserves the most campaign-level structure. In our corpus, it is the source that most consistently combines campaigns, intrusion sets, techniques, and relationships in one bundle. If reusable procedural structure is weak even there, it is unlikely to be stronger or more consistent in sparser heterogeneous feeds.

Frameworks such as MITRE Caldera provide an execution substrate for emulating adversary behavior, but translating CTI into

runnable procedures still requires explicit planning layers, parameter binding, and a declared *System Under Test (SUT)* [38, 47]. We therefore target the analyst, emulation engineer, or artifact author who wants to use public structured CTI as more than a coverage label. In our setting, the input is public structured CTI plus a declared SUT, and the desired output is an executable workflow together with an explicit record of what CTI did not provide. Success is not historical replay, but a reproducible separation between behavioral structure already encoded in CTI and the procedure that still must be added before execution. This framing motivates the central questions guiding this study:

RQ1: How much adversarial behavior do current ATT&CK-in-STIX artifacts capture for multi-step APT emulation?

RQ2: How can structured CTI be transformed into computable multi-stage behavioral plans for emulation?

RQ3: Which structural and semantic gaps in descriptive CTI prevent automation, and how can they be mitigated?

Our contributions are fourfold. ① We measure coverage, sparsity, overlap, and clustering in the MITRE ATT&CK Enterprise bundle and show that campaign objects expose narrow, heterogeneous slices of behavior rather than reusable procedural backbones. ② We show that campaign and intrusion-set associations do not supply the ordering, preconditions, or environment bindings needed for multi-stage execution. ③ We define a three-stage translation methodology that makes the automation boundary explicit: structural modeling is automated, technique translation is analyst-supervised, and execution is scripted once steps are fixed. ④ We corroborate that boundary with two focal case studies and an eight-adversary Docker audit, distinguishing reproducible execution progress from campaign-isolated replay. Together, these results show that public ATT&CK-in-STIX contains enough behavioral signal to ground enactment, but too little procedure to execute on its own.

2 Background

CTI refers to evidence-based knowledge about cyber threats, ranging from low-level artifacts (IoCs) to descriptions of tactics, techniques, and procedures (TTPs). In its unstructured form, CTI appears as narrative reports, blog posts, and vendor documents, which require manual normalization before they can be used systematically. STIX was introduced to reduce that heterogeneity by standardizing threat entities and relationships in a machine-readable format [30]. For this study, the relevant object types are attack-pattern, campaign, intrusion-set, malware, tool, and relationship. They capture behavioral entities and associations, but not, on their own, a campaign procedure chain.

Other structured models such as MISP and CASE make different trade-offs between simplicity and expressivity. We focus on ATT&CK-in-STIX because it remains the most widely adopted public representation of adversary behavior for cross-organizational CTI exchange and threat-informed defense [22, 30].

MITRE maintains the ATT&CK framework as a hierarchical knowledge base of TTPs observed in real campaigns, organized into matrices for different domains (Enterprise, Mobile, and ICS) [40]. In this taxonomy, *tactics* capture objectives, while *techniques* and *sub-techniques* describe modes of operation. Beyond the matrix itself, ATT&CK also indexes threat groups, campaigns, malware, tools, telemetry sources, and mitigations [40]. MITRE publishes this content as STIX bundles built from object types such as attack-pattern, intrusion-set, campaign, malware, tool, and relationship.

The conceptual layers are different. ATT&CK is the ontology of adversary behavior, STIX is the serialization language used to publish it, and the Enterprise bundle is one concrete STIX export in the broader CTI ecosystem. In ATT&CK, each technique or sub-technique is represented by an attack-pattern object with fields such as description, kill-chain phases, external references, and tactic mappings. These objects are the main building blocks used by extraction pipelines to align narrative reports with standardized technique identifiers [5, 35, 41].

Objects of type `campaign` represent specific operations attributed to a threat actor. They typically encode time windows, objectives, targeted sectors, and a subset of associated techniques, malware, or tools. In practice, however, CTI feeds rarely enumerate all steps, prerequisites, or action sequences. Threat reports often omit steps, merge phases, or present only fragments of the intrusion [35], and large-scale measurements report inconsistent field usage and heterogeneous reporting practices across providers [22]. As a result, campaigns encoded in STIX tend to lack the procedural specificity required for direct replay.

Objects of type `intrusion-set` aggregate the long-term behavior of a threat group across multiple campaigns, including commonly used malware, techniques, infrastructure, and motivations [1]. In open STIX collections, campaigns are linked to intrusion sets via `relationship` objects that encode attribution, tool usage, or technique associations. This modeling reflects a common CTI distinction: *intrusion sets* capture the persistent adversary profile, while *campaigns* represent concrete operational instances. Even then, actor and technique labels remain inconsistent across vendors, which reduces interoperability [43].

Despite its broad adoption, the STIX data model was designed to describe threat entities and relationships, not to reconstruct multi-host adversary behavior automatically [30]. Although ATT&CK-in-STIX provides structured identifiers for techniques, tactics, campaigns, and intrusion sets, it does not directly encode temporal order, explicit prerequisites, detailed environmental constraints, or branching logic. Relationship objects can state that an intrusion set "uses" a malware family or that a campaign is "attributed to" a group, but they do not specify how to chain those entities into an execution plan. Graphs built from these bundles therefore capture *which* entities are linked, not *how* to replay a campaign chain [35, 40, 41].

Open CTI collections also exhibit low coverage, delayed sharing, uneven field usage, and inconsistent labels [22, 43]. Extraction pipelines can recover partial behaviors from reports, but they still do not yield executable sequences with preconditions, parameters, control logic, and SUT bindings [5, 7, 13, 35, 41, 48]. Even when emulation tools such as Caldera are used, CTI descriptions still have to be transformed into ordered, parameterized plans, and current artifacts provide no formal SUT abstraction tying techniques to the environments in which they are expected to execute [36, 38, 45].

3 Related Work

Recent advances in structured threat intelligence, technique extraction, and adversary emulation have expanded the range of available methodologies. Prior work analyzes the structure and quality of CTI feeds published in STIX, including aspects such as heterogeneity, coverage, and field consistency, as well as their impact on commercial platforms and detection evaluations [22, 30, 36, 40, 41, 43, 45]. These studies quantify inconsistencies in field usage, rule annotations, and sharing practices, and show that both ATT&CK-annotated rules and other STIX sources suffer from uneven coverage and vendor-specific practices. However, they do not assess whether public bundles contain sufficient procedural information to support multi-host emulation without analyst reconstruction, nor do they systematically investigate sequencing, operational dependencies, or the environmental context required for direct execution. As a result, existing work falls short of directly converting descriptive CTI into executable multi-step representations, motivating the approach developed in this paper.

Solutions for deriving adversary behavior from unstructured text, such as Extractor [35], CTI HAL [11], and NLP-based extraction pipelines [5, 7, 17, 48], as well as LLM-powered command and script reasoning [13], advance the identification and organization of techniques, entities, and relationships. These approaches include supervised and weakly supervised extraction, Systematization of Knowledge (SoK)-style evaluations of TTP extraction quality, and LLM-based knowledge graph construction from CTI. However, they do not directly produce executable sequences from the structure already present in CTI bundles. They evaluate extraction quality rather than the completeness and sufficiency of the procedural structure encoded in STIX itself. Temporal relationships and execution conditions are inferred from narrative descriptions rather than assessed against the actual encoding in STIX bundles.

Closer in spirit to our measurement framing, Saha et al. [34] study how distinctive public threat-group profiles are for attribution. They show that only a minority of ATT&CK groups have group-specific techniques, and that software often provides stronger group-level signatures than techniques alone. Our setting is complementary rather than contradictory. We focus on campaign and intrusion-set profiles inside the Enterprise bundle and compute exact positive-evidence witnesses and subsumption cases in that corpus. We then ask a different systems question: even when a profile is distinctive enough to separate one campaign or group from another, does the underlying STIX representation contain the procedural semantics needed to execute it? Their work clarifies the limits of attribution specificity; ours clarifies the limits of procedural sufficiency for emulation.

In the field of detection and investigation, telemetry- and provenance-based systems use ATT&CK as an annotation taxonomy but reconstruct attack structure from logs rather than from CTI. Provenance-based detectors such as HOLMES, UNICORN, and ATLAS [1, 18, 29], followed by ALchemist and NODLINK [25, 50], show that correlating whole-system audit data is effective for reconstructing APT campaigns. Later work on provenance graph learning and scalable detection, including Flash, Kairos, DistDet, PROGRAPHER, and ProvG-Searcher [2, 8, 15, 42, 49], improves efficiency and search over large graphs.

Other approaches focus on tactic and technique recognition or online segmentation, such as TREC, TAPAS, SLOT, and OCR-APT [3, 26, 33, 51], or address lateral movement detection in temporal network graphs [23, 24]. Complementary measurements highlight practical and industrial aspects of provenance-based EDR and auditing, including operating costs, triage effort, and logging limitations [14, 21]. Together, these works provide detailed visibility into campaign behavior and operational constraints, but they do not treat STIX as a primary procedural source for emulation: the attack chains are reconstructed from telemetry rather than derived from CTI object structures.

Adversary emulation frameworks such as Laccolith [32], PentestGPT [12], PentestAgent [37], and language model-driven proposals for offensive planning and cyber deception [38, 39] rely on curated procedures, environment models, and execution logic that specify ordering, preconditions, and cleanup. Their evaluations operate over fixed, parameterized, or benchmarked SUTs rather than deriving procedure or environment directly from STIX bundles themselves. This shows that reproducibility depends on the description of attacker behavior and on explicit specification of the SUT. In particular, PentestGPT studies LLM-guided offensive interaction on benchmark targets, while InCALMO evaluates autonomous multi-host planning and execution over MHBench-style emulated networks through an explicit task and action layer.

Closely related standardization efforts already move in the same direction: OASIS CACAO playbooks [31] provide a shareable format for security workflows, and MITRE CTID Attack Flow [6] explicitly represents flows of ATT&CK techniques. Our setting is narrower and more diagnostic: we ask what fraction of that procedural burden can be derived from STIX itself before any analyst- or model-assisted translation layer is applied. Structured CTI provides technique identifiers and high-level behavioral context but still requires an additional translation step before it can be executed as a multi-stage procedure. We therefore evaluate the extent to which current STIX-encoded ATT&CK data contains, or lacks, the procedural semantics required for machine-actionable emulation.

Frameworks that operationalize adversary behavior help clarify what structured CTI does and does not provide. Planning-based systems such as AURORA [47] model actions through explicit preconditions and effects; the Effects Language (EL) formalism [10] demonstrates that executable coordination requires ordering and guarded effects; and knowledge graph approaches such as KNOWHOW [28] and MultiKG [46] enrich CTI with structure derived from telemetry or cross-source aggregation. These systems rely on procedural elements (ordering, parameters, bindings, and environment assumptions) that are not encoded in the current MITRE ATT&CK Enterprise bundle. Our methodology is therefore complementary: it identifies the procedural information missing from this bundle. It shows how descriptive CTI can be converted into representations suitable for multi-host emulation, while explicitly characterizing what current standards cannot automate. Additionally, to our knowledge, no prior work treats the ATT&CK Enterprise bundle itself as the object of measurement to assess its suitability for machine-actionable multi-step emulation.

4 Behavioral Metrics

Our analysis is supported by two components: the structure of STIX objects representing intrusion sets, campaigns, and techniques, and a set of quantitative measures derived from binary representations of technique usage. In the MITRE ATT&CK Enterprise, adversary behavior is expressed as a heterogeneous graph of typed objects. The main behavioral entities considered here are attack-pattern (techniques and sub-techniques), x-mitre-tactic (tactics), campaign, intrusion-set, malware, tool, course-of-action, and relationship. Auxiliary entities such as indicator, identity, report, note, and x-mitre-data-source provide contextual metadata but do not encode procedural behavior. Table 1 lists the freely available STIX sources included in the consolidated dataset.

Before our qualitative evaluation, we first quantitatively characterize these entities. Attack-pattern objects represent techniques and sub-techniques, and the subtechnique-of relationship encodes their hierarchy. Tactics are represented by x-mitre-tactic objects and are referenced by techniques through the kill_chain_phases field. The STIX schema does not include dedicated fields for procedural information; ordering, preconditions, environmental requirements, dependencies, and parameter flows remain in natural-language descriptions and are not machine-readable. For the quantitative analysis, each campaign is encoded as a binary vector that indicates the presence or absence of each ATT&CK technique. We choose the four metrics below because they probe complementary properties of reusable structure: breadth of documented behavior, matrix sparsity, pairwise reuse, and cluster cohesion.

Behavioral Metrics. Coverage: fraction of techniques and sub-techniques observed at least once across campaigns; Sparsity: proportion of zero entries in the campaign-technique matrix; Overlap: similarity between campaigns computed from shared techniques; Clustering: stability of structural patterns measured by the *silhouette* coefficient.

5 Data Sources

The selected dataset is the Enterprise bundle of MITRE ATT&CK in STIX format. It serves as the primary source of structured CTI for this study because it is publicly available, widely used in practice, and free of usage restrictions. MITRE distributes ATT&CK datasets for the Enterprise, Mobile, and ICS domains, all encoded in STIX, and the additional CTI collections examined here also follow the STIX object model. ATT&CK is commonly used to structure CTI and is relied upon by platforms such as Microsoft Sentinel, Microsoft Defender[1], Falcon[2], and government initiatives such as CISA[3].

We use this bundle (v18.1) as the authoritative source for all quantitative analyses in this study [40]. Additional non-versioned CTI sources were retrieved on 28 November 2025. Table 1 lists the objects obtained from each provider. The dataset will be released publicly after the completion of the double-blind review process. Although several feeds describe themselves as TTP collections, STIX does not define a structured procedure object; procedural behavior must therefore be reconstructed from contextual relationships such as *uses*, *attributed-to*, *targets*, *delivers*, and *executes*, or from narrative descriptions, particularly those found in campaign objects.

To ensure reproducibility, we specify the object counts used in our analysis. The Enterprise bundle contains 52 campaign SDOs, but one (C0033) lacks any *uses* relationships and is excluded, leaving 51 campaigns. The bundle includes 20,048 relationship objects in total, of which 17270 are *uses* relationships relevant to the behavioral links analyzed here. At the attack-pattern layer, the raw bundle exposes 835 ATT&CK technique or sub-technique objects with `T...` identifiers; 144 are revoked or deprecated, leaving the 691 active attack-pattern objects with behavioral content used in our quantitative metrics. All quantitative analyses presented in this paper (coverage, sparsity, overlap, clustering, campaign-group alignment) are computed exclusively on the Enterprise bundle.

We process STIX 2.x objects representing APT groups, their campaigns, observed behaviors, infrastructure, and kill-chain elements. This dataset catalogs indicators, tools, techniques, and sub-techniques, along with their associations with campaigns and intrusion sets. These objects provide structured entities and links, but not execution logic, ordering, or temporal constraints. We also performed a deduplication analysis using multiple comparison criteria across STIX objects. Apart from expected duplication in the EclecticIQ source, no redundant entries were found. The consolidated dataset contains 85,089 distinct objects.

For the specific goal of this work, systematic behavioral analysis and subsequent adversary emulation, we therefore restrict campaign-level quantitative analysis to the ATT&CK Enterprise subset. The remaining STIX sources are used only to characterize ecosystem-level diversity and coverage. In our parsed public-source corpus, Enterprise preserved the richest campaign-level behavioral structure, making it the most informative public baseline for procedural-sufficiency measurement.

6 Methodology

To evaluate whether structured threat intelligence can be transformed into machine-actionable representations for multi-stage adversary emulation, we propose a three-stage methodology defined at an abstract level. The approach is format- and platform-agnostic, requiring only structured behavioral entities and explicit relationships among them. In this work, we instantiate the methodology using STIX 2.1 objects and the Caldera framework to show how the three stages map onto a concrete toolchain.

Figure 1 presents the three conceptual stages of the methodology. Stage 1 performs automated structural modeling of CTI data. Stage 2 introduces an analyst-supervised translation from abstract behavioral descriptions to minimal executable steps. This translation can be assisted by public templates or language models, but it is always validated against the source CTI and the target environment. Stage 3 integrates these steps into an emulation environment. In the instantiation studied here, the automation boundary is explicit: Stage 1 is fully automated, Stage 2 is analyst-supervised,

[1]Available at: https://learn.microsoft.com/en-us/azure/sentinel/mitre-coverage?tabs=defender-portal
[2]Available at: https://www.crowdstrike.com/en-us/press-releases/crowdstrike-achieves-100-percent-mitre-engenuity-attack-enterprise-evaluation/
[3]Available at: https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping

Table 1: STIX sources in the consolidated dataset.

Source	Type	Objects	Unique	Duplicates	Description
MITRE Enterprise dataset	Repository	24,771	24,771	0.0%	Broad collection including TTPs, adversaries, and campaigns.
MITRE CAPEC	Repository	2,666	2,666	0.0%	Attack patterns.
DigitalSide	Repository	38,306	38,306	0.0%	Indicators, techniques, relationships, and malware with IOC focus.
AlienVault OTX	TAXII server	17,303	17,303	0.0%	Diverse objects including `attack-pattern` and `threat-actor`.
EclecticIQ	TAXII server	2,335	2,043	12.5%	Threat actors, campaigns, and reports.
Total (deduplicated)		**85,381**	**85,089**	0.0%	Nearly duplicate-free consolidated dataset.

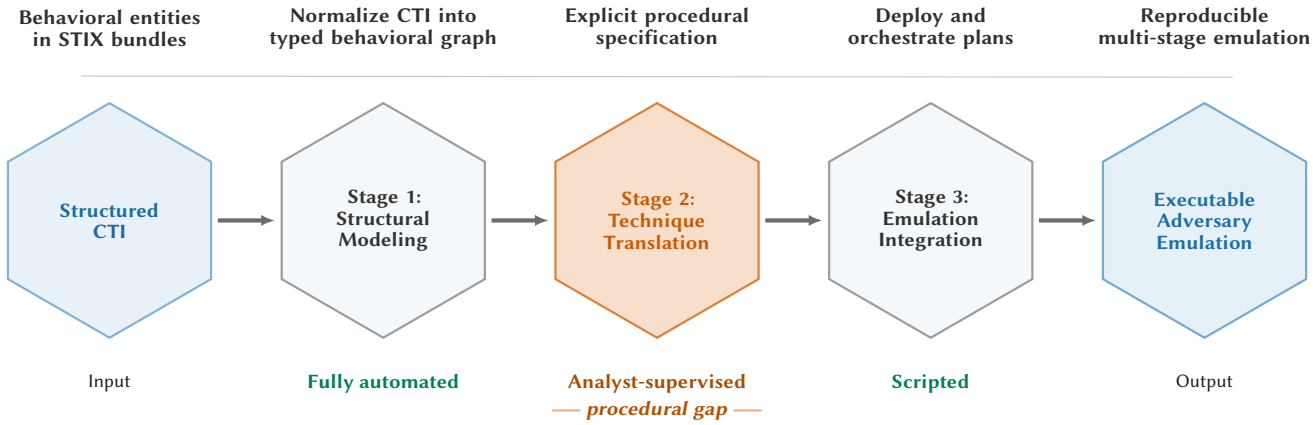

Figure 1: High-level structure of the methodology to convert descriptive CTI into executable multi-stage adversary behavior.

and Stage 3 is scripted once the translated steps are fixed. The figure is conceptual rather than an implementation diagram and does not assume any specific serialization.

6.1 Stage 1: Automated Structural Modeling

Structured CTI is modeled as a typed behavioral graph, where nodes represent entities such as techniques, campaigns, intrusion sets, malware, and tools, and edges encode relations such as `uses`, `attributed-to`, and `subtechnique-of`. Any CTI representation that exposes typed objects and explicit relationship fields can be normalized into this form. Each behavioral entity is mapped into a uniform internal representation. Techniques or equivalent abstractions are encoded as elements of a fixed behavioral space. Campaigns or long-term threat operations are represented as binary or categorical vectors denoting the presence of relevant techniques. Relationships are translated into vector entries.

Because structured CTI generally lacks explicit temporal or causal ordering, we derive a conservative tactic-ordered list for each campaign or intrusion set by aligning each technique with its associated ATT&CK tactic and placing it along the canonical progression from Reconnaissance to Impact. Since a technique may be related to multiple tactics via the `kill_chain_phases` field, we assign it to one tactic by selecting the earliest tactic in this canonical order, with remaining ties broken deterministically using the technique's external identifier. This ordering is used strictly as an organizational scaffold rather than as a temporal or causal sequence. The scaffold provides a stable organizational backbone without introducing procedural semantics absent from the original CTI.

Sequence-comparison analyses (e.g., LCS) over these lists later test whether campaigns exhibit stable, reusable chains of techniques. Stage 1 yields a normalized behavioral graph, matrices linking campaigns or threat groups to techniques, and tactic-ordered technique lists that serve as structural scaffolding for subsequent stages.

6.2 Stage 2: Technique Translation Layer

Stage 2 bridges the gap between high-level behavioral descriptions and executable steps. Existing CTI typically states *what* occurred, not *how*, and therefore lacks the procedural semantics needed for automation. Some interpretation is required to fill this gap.

Stage 2 operates on a campaign's tactic-ordered technique list rather than on the raw order of bundle objects. For orientation, Figure 2 summarizes attack-pattern counts in the composed corpus after assigning each object to one tactic bin for visualization and placing the bins in the canonical ATT&CK Enterprise tactic order; the translation itself uses only the 691 Enterprise attack-patterns with behavioral content. For each technique in the tactic-ordered list, we extract the behavior implied by the structured representation and check whether prior examples or public repositories (e.g., Atomic Red Team - ART) offer templates. We optionally use language-model assistance to draft candidate commands and then refine the action against platform constraints, privilege requirements, and environmental assumptions.

The result is an executable step that captures the intended behavior without contradicting the available intelligence. When parameters, preconditions, or environmental bindings are absent from the structured input, we document them explicitly. We also record lightweight provenance to preserve traceability between CTI entities and the resulting steps. Stage 2 therefore produces context-aware executable steps together with explicit documentation of assumptions and provenance.

A concrete example illustrates the role of Stage 2. In ShadowRay, structured CTI and ATT&CK identify `T1190` (Exploit Public-Facing Application) and describe abuse of exposed Ray services, but they do not specify the exact endpoint, parameters, or success check needed in the laboratory SUT. A Stage 2 seed can therefore start from a generic template or placeholder command and then be bound to the environment by the analyst. In our Docker-backed instantiation, this binding yielded the concrete command `curl -X POST -F 'cmd=whoami' http://172.21.0.20:5055/exec`. What comes from CTI is the behavioral intent and campaign context; what must be added is the specific target address, exposed service, request format, and validation logic. Stage 3 does not infer any of these elements; it only packages the validated command as a Caldera ability and executes it.

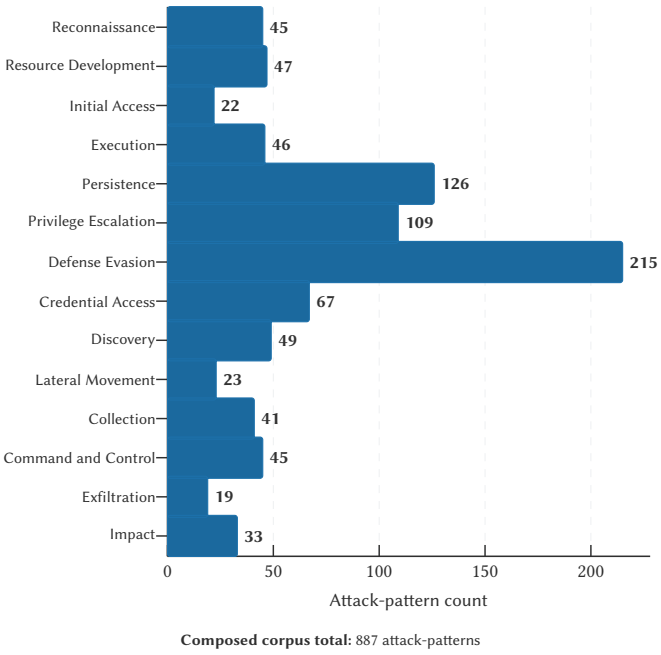

Figure 2: Technique count by MITRE ATT&CK Enterprise tactic across the composed STIX dataset. Tactics are shown in the canonical Enterprise matrix order from Reconnaissance to Impact. For this ecosystem-level summary, each attack-pattern is assigned to one tactic bin, so the horizontal bars sum to 887 attack-pattern objects across all sources in the composed corpus. Quantitative analyses in this paper use only the 691 Enterprise attack-patterns with behavioral content (Section 5).

The analyst's role is limited to validating ordering, environmental assumptions, and parameter binding rather than inventing the behavioral scaffold from scratch. In our focal workflows, the dominant Stage 2 effort was binding missing parameters and checking SUT consistency. The end-to-end translation took on the order of one analyst-hour per workflow after Stage 1 had already produced the tactic-aligned scaffold. We report this only as a qualitative effort bound, not as a universal benchmark or an inter-analyst stability claim.

6.3 Stage 3: Emulation Integration

Stage 3 converts the translated steps into an executable adversary representation. Any emulation environment capable of expressing actions, plans, and controlled execution can instantiate this stage. Each step becomes a platform-aware action with optional preconditions and postconditions. Ordered sets of actions form a behavioral plan that approximates a campaign or long-term threat operation, enabling consistency checks, assumption validation, and telemetry collection.

In this study, we instantiate Stage 3 using Caldera. Translated steps are mapped to abilities, adversary profiles, and operations. Abilities specify execution logic, expected output, and cleanup procedures; adversary profiles define the ordered set of abilities; and operations orchestrate execution, timing, agent assignment, and logging. Support scripts automate ability ingestion, profile construction, and repeated execution via the REST API. Once the human-curated steps are defined, all repetitive aspects of emulation are automated.

In our experiments, Stage 1 is instantiated with the STIX 2.1 Enterprise bundle, Stage 2 applies our translation procedure using ATT&CK entries and structured CTI as authoritative sources, and Stage 3 maps the translated steps into Caldera artifacts. This separation keeps the methodology independent of any specific CTI format or emulation framework while enabling us to assess the limitations of available structured intelligence. Operationally, the methodology consumes structured CTI and a declared environment description, and it yields executable steps plus an explicit record of what the CTI did not provide.

To evaluate the methodology, we instantiate two case studies inspired by structured CTI, *ShadowRay* and *Soft Cell*. Their translated steps are analyzed in the legacy Docker-backed Caldera environment to test whether CTI-derived behavior can be enacted coherently once the missing procedure is made explicit. The result is not historical replay, but a controlled test of procedural completeness on a reproducible substrate.

Overall, the methodology provides a format-agnostic process for transforming descriptive structured CTI into a computable behavioral representation suitable for multi-host adversary emulation.

7 Behavioral Analysis

Our analysis starts from two complementary views of the data. The first is the *composed* STIX dataset, which aggregates multiple public CTI collections (including MITRE ATT&CK Enterprise, CAPEC, DigitalSide, AlienVault OTX, and EclecticIQ). The second is the

MITRE ATT&CK Enterprise bundle itself, i.e., the official knowledge base maintained by MITRE for the Enterprise domain, serialized as STIX 2.x objects and periodically updated.

The distinction matters. STIX is a generic interchange format that defines object types and relationship structures for CTI. ATT&CK is a behavioral knowledge base that organizes tactics, techniques, intrusion sets, campaigns, malware, and tools. The Enterprise bundle is one concrete STIX export of this knowledge base. The composed dataset broadens this export by incorporating additional STIX feeds that follow the same data model.

We first executed the whole processing pipeline on the composed dataset by parsing all bundles, deduplicating objects, constructing a typed graph, deriving campaign-technique vectors, and computing coverage, overlap, and clustering statistics across sources. The additional feeds increase breadth and redundancy by contributing more objects, including indicators and malware families. However, their campaign and intrusion-set descriptions are typically shorter and less structured than those found in MITRE ATT&CK Enterprise.

For emulation purposes, the composed dataset and the Enterprise bundle share the same structural limitation: STIX does not define a dedicated procedure object with explicit ordering, preconditions, and environment bindings, and none of the sources in our corpus introduces such a construct as a custom extension. Consistent with prior work on CTI quality, we therefore find that most STIX-encoded artifacts remain sparse, incomplete, and procedurally underspecified. Campaign objects in particular rarely document the full incident, target environment, or execution prerequisites in machine-readable form.

The practical difference is one of degree rather than kind. Among the public feeds we parsed, the ATT&CK Enterprise bundle still preserves the richest campaign-level structure, so we use it as the basis for the detailed behavioral analysis and clustering that follows. Each campaign is represented as a binary vector over Enterprise techniques, indicating which techniques appear at least once in that campaign. Intrusion sets are defined analogously from STIX `relationship` objects linking intrusion sets to `attack-pattern` or technique identifiers.

The Enterprise data contains more documented threat groups than publicly available campaigns. Each group is linked to one or more sets of techniques spanning phases such as Initial Access, Persistence, Privilege Escalation, Credential Access, Discovery, Lateral Movement, Command and Control, Collection, Exfiltration, and Impact. Together, these techniques form the group's *operational profile*, which is useful for connecting activity across campaigns, attributing incidents, and designing behavior-centered defenses.

We then compare campaigns with their corresponding intrusion sets to assess internal consistency in the Enterprise bundle. Because campaign entries are most informative when treated as technique sets, we examine how each campaign's techniques relate to those attributed to its corresponding intrusion set. Both sides of the comparison come from the same Enterprise STIX representation used in the coverage and clustering analyses. We then manually cross-check a sample of these relationships against the ATT&CK website.

By comparing the techniques observed in each campaign with those listed for the associated intrusion set, we find strong asymmetry in both directions. Across the 22 active campaign–intrusion-set attribution pairs with techniques on both sides, the median Jaccard overlap is only 10.0%, and every pair covers less than half of the linked intrusion-set technique set. This is partly structural: intrusion sets aggregate behavior across multiple campaigns, whereas campaigns encode narrower operational slices. Even so, the relation is operationally weak because the linked intrusion-set profile often contributes much more behavior than the campaign itself documents.

A representative example is the *Juicy Mix* campaign, which is linked to the *OilRig* intrusion set: 64.3% of the campaign's techniques appear in OilRig, but only 11.8% of OilRig's documented techniques appear in Juicy Mix, as encoded in the Enterprise bundle. Our manual cross-checks against the ATT&CK website revealed concrete cases in which the downloadable bundle and the website diverged on campaign–intrusion-set relationships. This shows that even frequently updated bundles can contain discrepancies in these links.

We do not attempt to model the exact source of these mismatches. For emulation, the practical implication is narrower: campaign-group mappings in the downloadable bundle should be treated as curated data that can diverge from the website and may therefore require spot checks in sensitive cases.

The composed dataset from Section 5 broadens coverage across threat domains and allows cross-checks between providers [22]. It does not, however, add procedural depth: all sources rely on the same STIX object model, and none introduces structured fields for ordering, preconditions, or environment bindings beyond what the standard already provides. This is why the detailed quantitative analysis and emulation experiments use the Enterprise bundle: in our corpus, it preserves the most campaign-level structure even though it remains sparse and imperfect.

To better understand the behavioral structure encoded in Enterprise intrusion sets, we compute similarity from their technique vectors and apply principal component analysis (PCA), using the Jaccard distance as the similarity measure based on the presence or absence of the technique in the intrusion sets. Figure 3 presents the resulting PCA. The projection forms a dense near-origin cloud without clearly separated families, suggesting that intrusion sets do not form coherent behavioral groupings. Instead, each intrusion set comprises a relatively small, idiosyncratic subset of techniques. Although intrusion sets cover more techniques than individual campaigns, they do not provide complete procedures. They usually do not capture relationships or the operational context among techniques. Therefore, while they are useful for high-level profiling, they are not adequate as standalone units for emulating adversaries without significant contextual reconstruction.

We also investigate whether common behavioral subsequences can be derived across campaigns. The operational assumption is simple: if Enterprise campaigns shared a stable technique backbone, a recurring subsequence should appear in tactic-ordered technique lists and could serve as a generic emulation template. For structural ordering, we use the canonical ATT&CK tactic progression. This provides a consistent reconnaissance-to-impact

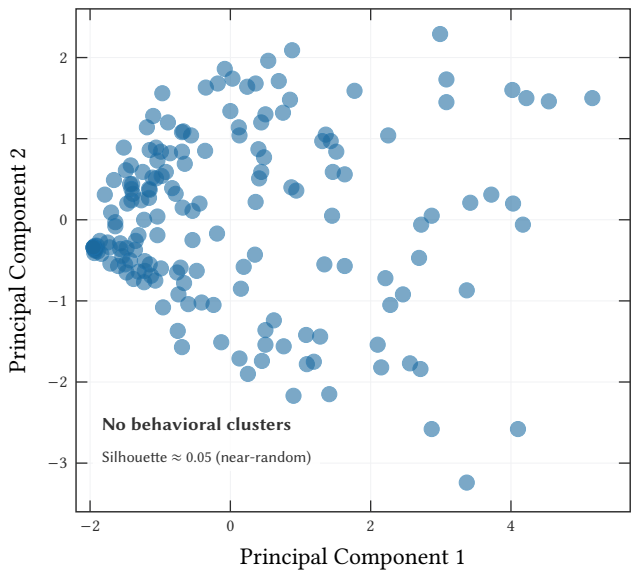

Figure 3: Technique-based similarity of 172 MITRE ATT&CK Enterprise intrusion-sets.

scaffold without claiming that it reconstructs the chronology of any specific incident.

To quantify structural stability, we apply k-means clustering to the campaign-technique binary vectors and measure cohesion with the silhouette coefficient. We report $k = 7$ because it yields an interpretable partition relative to the dominant tactic phases, not because we claim it is the statistically unique choice. Both the cluster assignment and the silhouette calculation use the same Euclidean geometry over these binary vectors. We use this consistently as a coarse structural probe, not as a claim that Euclidean distance is the only meaningful behavioral similarity notion.

At $k = 7$, the mean silhouette score is 0.05 (range $[-1, 1]$; values near zero indicate near-random assignment). As a baseline, we generate 1,000 random binary matrices with identical dimensions and sparsity and obtain a mean silhouette of -0.01 ± 0.01. A sensitivity sweep over $k \in [2, 10]$ produces the same qualitative picture, with silhouettes remaining low throughout ('0.03'–'0.11'). A supplementary average-linkage agglomerative clustering run on Jaccard distances leaves the conclusion unchanged: silhouettes stay between 0.03 and 0.05 across the same k range, including 0.03 at $k = 7$. The real data therefore shows little reusable structure beyond chance. This directly refutes the operational assumption that campaign technique sets cluster into reusable behavioral families.

For sequence analysis, we compute the LCS between all $\binom{51}{2} = 1{,}275$ campaign pairs using the tactic-ordered technique lists. If campaigns shared a stable behavioral backbone, we would expect long common subsequences suitable as emulation templates. Instead, the mean LCS length is 2.8 techniques (median 2.0, max 29), and no pair shares more than a small fraction of its list with another. This conclusion is stable under tactic reassignment for multi-tactic techniques: across 200 randomized valid-tactic trials, the mean LCS remains between 2.727 and 2.760 and the median stays fixed at 2.0.

These results are consistent with the weak-cluster picture in Figure 4 and with prior studies that report sparsity, inconsistency, and incomplete behavioral specification in CTI sources [22, 35, 41]. Because the tactic-ordered lists are an organizational scaffold rather than a recovered timeline, the LCS results should be read as a descriptive probe of reusable structure, not as evidence about true chronological subsequences. Our negative result does not rely on this scaffold alone: the same picture already appears in unordered coverage, overlap, binary-vector clustering, and the order-free itemset probe in Appendix E. In practice, the analysis reveals no robust common subsequence between campaigns and no universally shared pair of techniques. Appendix E reports a supplementary order-free probe with the same conclusion: even the most frequent five-technique itemset appears in only 6 of 51 campaigns (11.8%).

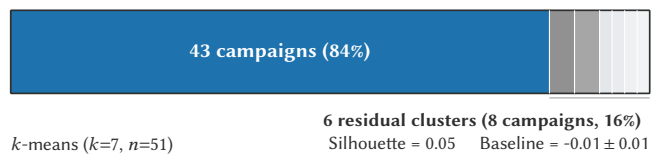

Figure 4: Campaign cluster sizes induced by k-means over technique-overlap vectors. The area chart shows how 51 Enterprise campaigns are partitioned when clustered with $k = 7$, highlighting one dominant cluster and several tiny residual clusters rather than well-separated behavioral families.

A common operational assumption is that APT campaigns share a stable behavioral backbone suitable for generating generic emulation profiles. Our analysis of the 51 Enterprise campaigns contradicts this view. Campaign coverage is sparse: only 43.0% of all Enterprise techniques appear in at least one campaign, leaving 57.0% unused in any campaign instance (Figure 5).

No technique is universal, and even the most frequent ones are far from ubiquitous. The most frequent technique, `T1105` (Ingress Tool Transfer), appears in 28 campaigns (55%). No single technique appears in every campaign, and no pair of techniques co-occurs universally. The long-tailed frequency distribution and low-cohesion clusters together indicate that campaigns are idiosyncratic. A small number of behaviors, such as `T1105`, `T1588.002`, and `T1071.001`, appear in many campaigns, while most techniques are rarely used.

At the same time, narrowness does not imply indistinguishability. Using positive-evidence identifiability over the current Enterprise campaign-technique profiles, we find that all 51 campaigns are distinguishable from the others by some subset of their own techniques, and every campaign admits a distinguishing witness of size at most three. Formally, a witness for campaign C is a subset of techniques in C that is not contained in any other campaign profile; we compute the minimum witness exactly over the reduced campaign-difference sets.

This is a structural result about profile separability, not a claim about attribution in the wild or about procedural completeness. Under the same model, 145 of 168 intrusion-set profiles are distinguishable, while 23 are subsumed by larger profiles and admit no positive witness. Campaign objects can therefore be distinctive

as sparse behavioral slices while still remaining too underspecified to execute directly.

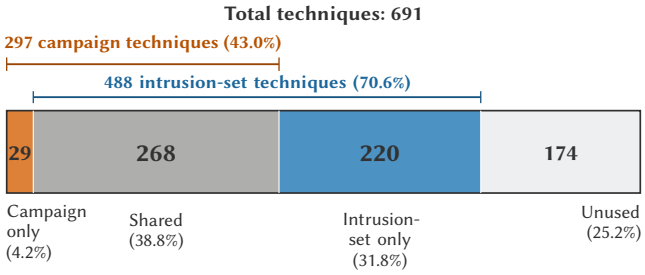

Figure 5: Technique usage across 51 MITRE ATT&CK Enterprise campaigns and 172 intrusion sets.

These results are consistent with prior studies that report structural variability, sparse field usage, and difficulty extracting actionable temporal structure from public CTI [22, 35, 41]. Our contribution is to connect those well-known data-quality problems directly to the emulation setting: publicly available CTI may still distinguish behaviors, but it does not expose the regular procedural structure needed to derive reusable execution templates.

The main findings are synthesized as follows:

Campaign heterogeneity: Enterprise campaigns employ sparse technique subsets: no single technique is universal, and clustering/LCS analyses reveal no common behavioral backbone across campaigns.

Technique dispersion: Only 43.0% of MITRE ATT&CK Enterprise techniques appear in any campaign (Fig. 5), yielding a long-tailed frequency distribution with no dominant core of shared behavior.

Positive-evidence identifiability: Despite this sparsity, all 51 campaign profiles are distinguishable within the Enterprise corpus by small positive witnesses, with all campaigns separable by at most three techniques. Under the same model, 145 of 168 intrusion-set profiles are distinguishable, while 23 are subsumed by larger profiles. Distinguishability in profile space therefore does not imply executability.

Intrusion-set coverage: Intrusion sets account for 70.6% of Enterprise techniques and preserve broader, less fragmented behavioral profiles than individual campaign objects.

Structural asymmetry: Across 51 campaigns, 297 techniques are used, and 29 of them do not appear in the corresponding intrusion-set profiles. Intrusion sets, by contrast, use 488 techniques, including 220 that appear in no campaign. This asymmetry shows that campaigns encode narrow episodic slices of activity, while intrusion sets span a broader behavioral space.

Broken campaign-group mapping: Several campaigns are linked to intrusion sets with limited technique overlap, and some campaign technique sets contradict their group-level profiles, reflecting inconsistencies between website and Enterprise bundle relationships (e.g., Juicy Mix vs. OilRig).

IOC role: Although IoCs are not the focus of our quantitative analysis, our findings align with prior work that treats indicators primarily as short-lived signals for triage and hunting, rather than as sufficient input for reconstructing multi-step adversary behavior or for robust attribution.

Modeling implication: For adversary emulation, intrusion-set-centric modeling preserves more behavioral coverage than campaign-centric approaches, and current STIX-encoded campaigns should be treated as partial behavioral hints rather than procedural templates.

8 Emulation Setup

In Stage 1, the relevant intrusion sets, campaigns, and techniques are loaded directly from the STIX bundle and ordered with the conservative tactic scaffold introduced earlier. Stage 2 then refines those abstractions into runnable commands through analyst validation rather than historical reconstruction.

In this study, Stage 3 uses Caldera 5.3.0 strictly as an execution engine. Caldera does not interpret STIX objects, infer sequencing, or supply missing parameters. Each translated technique therefore becomes an explicit Caldera ability with one command and, when appropriate, cleanup logic; the resulting abilities are arranged into adversary profiles using the Stage 1 scaffold. When a step fails, the failure points to a missing assumption, parameter, or precondition in the CTI-derived representation rather than to framework-side inference.

Experiments were conducted in a fully isolated containerized testbed built from the legacy Docker artifact, a frozen package of eight curated adversary workflows plus shared attacker/target service definitions, with a Caldera server, an attacker-side Kali agent, and target-side services connected through private Docker networks. In this setup, Caldera functions as the emulation orchestrator and the Kali agent serves as the execution agent, consistent with the conceptual components in Figure 6. The environment is not intended to approximate a real victim infrastructure. Its role is to provide a stable substrate for testing whether CTI-derived steps can be enacted without contradiction.

Concretely, the audited substrate is composed of four containers connected through three private Docker networks: a Caldera server, a Kali execution node, an exposed Nginx service, and an internal database service. We report this topology only to bound reproducibility of the shared laboratory base, not to claim that the environment reconstructs the historical victim networks behind the focal campaigns.

Operationally, each enactment experiment requires four elements: a substrate to run on, the campaign-relevant weaknesses or exposed services that make the steps executable, a translated workflow, and observable execution traces. Importantly, the legacy artifact preloads campaign-specific target bootstrap scripts into one shared laboratory substrate rather than provisioning a fresh per-campaign SUT. As a consequence, even campaigns that historically involved multiple hosts, such as Soft Cell, are evaluated here as procedural enactments over a common controlled environment. Any observed progress or blocking point must be interpreted in that context.

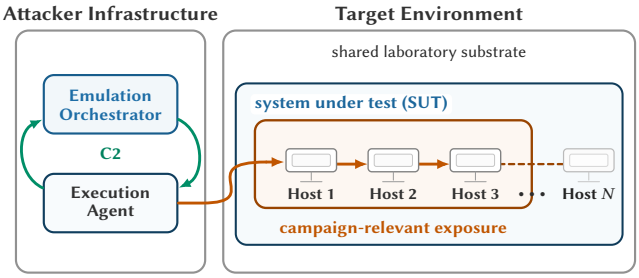

Figure 6: Isolated environment used for executing CTI-derived behaviors. The left panel shows the attacker infrastructure, composed of the Caldera orchestrator and a Kali execution agent linked by a command-and-control loop; the right panel shows the shared laboratory substrate, containing a declared system under test (SUT), with the campaign-relevant exposure highlighted across one or more target hosts.

Figure 7 makes this boundary concrete for one representative ShadowRay step. More generally, mapping each CTI-derived technique to an executable step requires adding elements that are not present in structured CTI: concrete parameters (paths, hostnames, ports), privilege assumptions, environment checks, and some context (e.g., which process to inspect or which directory to write to). Their purpose is to allow execution while remaining faithful to the technique's behavioral intent.

For each proof-of-concept case study, execution followed five fixed steps. ① load the intrusion sets, campaigns, and techniques and order them according to the tactic-aligned scaffold (Stage 1). ② translate technique descriptions into executable commands (Stage 2). ③ prepare the Docker-backed runtime substrate, wait for campaign-relevant services to appear, wait for a trusted `red` agent to reach stable beaconing, load the adversaries and abilities into Caldera, and create operations from adversary profiles (Stage 3). ④ collect operation outputs, link-level execution traces, and logs for consistency checking. ⑤ rebuild the runtime context when a fresh replay is required so that reruns remain comparable. The same Stage 3 setup also supports the broader audit of the eight curated adversaries embedded in the legacy artifact.

Under this setup, the operations ingest and execute the translated abilities without framework-side inference. Executed work is visible through Caldera link chains even when the higher-level step list remains empty, so we treat chain progress and the final observed link chain as the execution outcome. Intermediate non-zero link statuses can disappear as the chain continues to advance, so we score runs at a quiescent plateau rather than from an instantaneous scheduler snapshot.

We therefore report three observable outcomes: successful-link count, whether the workflow reaches an explicit end-of-workflow marker, and whether residual non-zero links remain at plateau. In the legacy artifact, an explicit end-of-workflow marker is the terminal `T1529` ability named `END OF ...`; residual non-zero links are links that still remain in a non-success state once chain activity has stabilized. Across the eight curated Docker adversaries, we observe measurable progress in all eight workflows, totaling 109 successful links. The per-workflow successful-link count has median 11 and range 7–24. All eight reach explicit end-of-workflow markers within the observed window, and none retains residual non-zero links at plateau.

The artifact therefore automates substrate preparation, service-level warm-up, workflow execution, and evidence capture on a shared laboratory base. It does not generate procedures from CTI, and the eight-adversary audit should not be read as a causal estimate of how much of each workflow comes from structured CTI versus later curation. It shows only that CTI-derived steps, once supplemented with analyst-supplied preconditions, parameters, and environment assumptions, can form internally consistent execution chains on the legacy substrate.

The emulation experiments also expose the remaining structural limitations. Prerequisites and environmental dependencies must still be introduced during translation, and branching or conditional logic cannot be recovered directly from the structured representation. The current ATT&CK Enterprise bundle, serialized in STIX, can therefore support reproducible multi-step enactment only after explicit procedural enrichment by a human analyst.

9 Case Studies

Before turning to the focal workflows, we bound the corpus-wide translation envelope that those workflows sit inside. From the 51 MITRE ATT&CK Enterprise campaigns and 172 intrusion sets, 168 intrusion sets (97.7%) have at least one associated technique, while 4 (2.3%) contain no technique relationships. Across the populated intrusion sets, we observe 4362 technique references, yielding an average of 26.0 techniques per intrusion set. All intrusion sets with at least one technique are included in the technique-based measurements.

We then applied our methodology to all 691 Enterprise techniques to bound the potential for generic emulation. Of these, 32 are platform-agnostic (e.g., strategic preparation steps that have no corresponding OS-level command) and cannot be instantiated as executable Caldera abilities on a concrete SUT. We mapped the remaining 659 techniques to single-step Caldera ability representations in our tooling. This corpus-wide mapping establishes representational coverage, not cross-platform execution fidelity. We then use two case studies to show how those translations behave once embedded in concrete adversary workflows: ShadowRay as a Docker-backed execution case and Soft Cell as a multi-host reconstruction case. In parallel, we audit all eight curated Docker adversaries packaged in the legacy artifact to measure how far translated workflows progress, terminate, and still depend on shared-substrate preparation and runtime repair outside the frozen artifact.

To ground our methodology, we selected one campaign with a directly represented adversary in the legacy Docker artifact (ShadowRay) and one multi-host intrusion-set-derived case study (Soft Cell) to determine how much of their documented behavior can be operationalized from structured CTI and where analyst-supplied assumptions remain unavoidable. The goal was not to reproduce the historical intrusions, but to assess whether the technique-level behavioral structure encoded in STIX and ATT&CK is sufficient to instantiate coherent multi-step enactment plans.

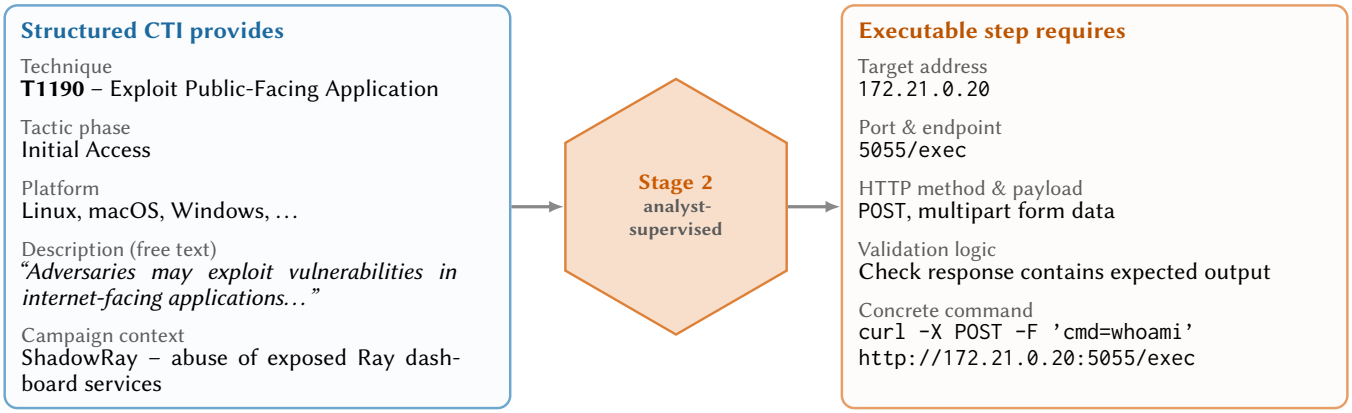

Figure 7: Concrete illustration of the procedural semantics gap using the ShadowRay T1190 technique. The left panel shows what structured CTI encodes; the right panel shows what Stage 2 must supply before execution. Parameters, bindings, and validation logic are absent from the STIX representation and must be reconstructed by the analyst.

ShadowRay is associated with exploiting perimeter systems and abusing credentials, and the legacy Docker artifact exposes a matching adversary workflow that lets us observe direct execution progress. Soft Cell, a multi-year intrusion into telecommunications networks, is represented here through the GALLIUM intrusion-set material and highlights the additional assumptions needed to reconstruct a multi-host procedure. The broader Docker audit complements these focal cases by showing that the same legacy substrate carries eight curated adversaries to explicit workflow termini, but only on a shared laboratory substrate rather than through independent clean-room replay. Despite differences in scope and tooling, both focal cases reveal the same structural gap: CTI supplies behavioral grounding, but not runnable procedure.

For each focal workflow, we extracted the relevant techniques from the underlying STIX objects and aligned them with the canonical tactic ordering used throughout this work. Following the methodology of Section 6, each technique was translated into an executable step. Discovery and enumeration actions required only generic commands, whereas steps related to Initial Access, Persistence, Privilege Escalation, and Exfiltration required parameters and assumptions not present in CTI (e.g., file paths, hostnames, credentials, and privilege levels).

The evidentiary stack is broader than the two focal cases alone. It includes corpus-scale structural measurement, corpus-wide technique-to-ability translation coverage, two worked focal cases, and a broader eight-adversary execution audit. Table 2 summarizes that stack explicitly. This framing is more informative than a tactic-by-tactic overlap inventory because each layer of evidence clarifies a different part of the automation boundary.

At the tactic level, the two focal cases still overlap in standard APT phases such as Initial Access and Execution, yet diverge once persistence, lateral movement, collection, and exfiltration depend on environment-specific assumptions. Each translated step was implemented as a single Caldera ability using explicit commands and cleanup logic. In the Docker-backed legacy environment, ShadowRay progresses through multiple successful links and reaches an explicit end marker, but only after environment-specific binding of service endpoints, request formats, and validation logic.

Soft Cell is the complementary reconstruction case. It shows how the same translation procedure quickly accumulates host, privilege, and routing assumptions once the narrative spans multiple hosts. Because Caldera performs no inference or auto-correction, any missing parameter, privilege assumption, ordering dependency, or substrate mismatch surfaces directly as blocked or uninstantiable procedure logic. Together, the focal cases act as a direct test of procedural completeness.

The results make explicit the structural limitations identified in Section 7. STIX objects do not encode execution order; they lack parameters, environment bindings, and privilege requirements; and they contain no branching logic or preconditions. Nevertheless, the case studies and the eight-adversary Docker audit show that structured CTI provides sufficient behavioral grounding to support reproducible multi-step enactment experiments when supplemented with an analyst-supervised translation layer. This demonstrates the methodology on a controlled substrate and clarifies where current CTI standards fall short for automation.

10 Discussion and Implications

Our main result is simple: public ATT&CK-in-STIX identifies adversary behavior, but it does not encode the procedure needed to automate it. We center the measurement on the Enterprise bundle because it preserves the densest campaign-level structured signal among the public feeds we parsed; the goal is to test procedural sufficiency where the signal is strongest, not where cross-feed noise is greatest.

Quantitatively, campaigns are sparse, heterogeneous, and do not form stable structural clusters. They can still be distinctive as corpus profiles: in the current Enterprise bundle, every campaign is distinguishable from the others by a small positive witness, even

Table 2: How the full evidentiary stack is organized. The paper combines corpus-scale measurement, corpus-wide translation coverage, two focal worked examples, and a broader Docker-backed execution audit.

Evidence layer	Scope	Role in the argument	What it demonstrates
Enterprise structural measurement	51 campaigns, 172 intrusion sets, and 691 attack-patterns in the current Enterprise bundle.	Quantifies coverage, sparsity, overlap, clustering, LCS behavior, and identifiability from structured CTI alone.	Campaigns are sparse and idiosyncratic; intrusion sets are broader but still do not encode executable procedure.
Corpus-wide translation coverage	659 translatable Enterprise techniques after excluding 32 platform-agnostic techniques with no concrete OS-level command.	Bounds how much of the technique space can be represented as single-step Caldera abilities in our tooling.	Establishes representational coverage, not universal cross-platform execution fidelity.
ShadowRay (focal campaign)	Campaign object plus associated ATT&CK techniques; directly represented in the legacy Docker artifact.	Shows how a directly represented campaign becomes runnable after explicit Stage 2 binding.	Direct Docker-backed execution case: once service endpoints, request formats, validation logic, and environment-specific bindings are supplied, the workflow makes reproducible progress and reaches an explicit end marker on the shared substrate.
Soft Cell (focal reconstruction)	Intrusion-set-derived GALLIUM material plus the multi-host telecom intrusion narrative used to reconstruct the procedure.	Shows how multi-host reconstruction accumulates host topology, routing, privilege assumptions, and per-host command binding.	Multi-host reconstruction case: the procedural burden grows quickly when CTI spans several hosts and lacks machine-readable environment structure.
Eight-adversary Docker audit	Frozen legacy artifact containing eight curated workflows on one shared laboratory substrate.	Broadens execution evidence beyond the focal walkthroughs and exposes substrate-level dependencies in replay.	Corroborating execution breadth: all 8 workflows progress, totaling 109 successful links; all 8 reach explicit end markers; none retains residual non-zero links at plateau. This demonstrates shared-substrate enactment, not isolated campaign replay.

though those same campaign objects remain procedurally incomplete. Distinctiveness in profile space is therefore much weaker than executability.

Operationally, the case studies and Docker-backed audit show that each executable step still requires explicit assumptions about the target environment, platform constraints, or privilege levels. Once those missing elements are supplied, the resulting workflows can make reproducible progress on a shared laboratory substrate. We therefore interpret the measurements as evidence about the semantic structure encoded in STIX, not as reconstructions of ground-truth campaign timelines.

This also explains why our campaign-side identifiability result does not conflict with Saha et al.'s group-level attribution findings [34]. They study threat-group specificity and show that many groups lack exclusive technique signatures. We instead show that Enterprise campaign profiles can still be separable within the bundle while remaining procedurally incomplete. Distinctiveness, in other words, is not the same as executability, and campaign-level separability is not the same as robust threat-group attribution.

Automation baseline and the reducible fraction of manual effort.

To bound what rule-based automation can achieve without analyst intervention, we audit all structured fields in the Enterprise bundle for procedural content. Stage 1 (structural modeling) is fully automatable: `kill_chain_phases` (100% populated) provides tactic ordering, and `x_mitre_platforms` (100% populated) scopes the OS family. Our pipeline uses both fields directly.

Stage 2 (technique translation), however, requires parameters, platform-specific commands, privilege assumptions, and environment bindings. The only candidate structured field for this layer is `x_mitre_system_requirements`, which is absent from all 691 active Enterprise techniques in our dataset. Other ATT&CK metadata is empty as well in the current export: `x_mitre_detection` has 0/691 non-empty values, and `x_mitre_data_sources` plus `x_mitre_permissions_required` are absent from all 691 techniques. A rule-based baseline that exploits all structured fields therefore fully automates Stage 1 but contributes nothing to Stage 2 in the current Enterprise bundle. The remaining work stays in free-text interpretation and environment binding. Appendix D summarizes the field-population counts behind this automation-baseline claim.

Free-text descriptions can still provide hints, but they do not expose a machine-readable procedure object with explicit parameters, guards, or execution bindings. This is why Stage 2 remains analyst-supervised even after Stage 1 has already produced a tactic-aligned scaffold.

A second implication concerns environmental sensitivity. Real intrusions reflect the victim organization's topology, identity model, security controls, and operational workflows. As shown in prior work on provenance-based detection [18, 29, 42], behavior

is profoundly shaped by environmental constraints. Because STIX does not encode such context, emulations generated solely from CTI risk misrepresenting preconditions or producing unrealistic execution paths unless additional environment modeling is performed. This requirement is inherent to the current CTI standards, which do not encode SUT-level assumptions.

These characteristics have practical consequences for defenders. Once enriched, CTI-derived emulations provide testable approximations of adversary workflows that can expose visibility gaps, validate telemetry and detection pipelines, and measure the resilience of analytic rules. Variation in parameters, supporting tools, or execution timing, whether analyst-supplied or LLM-proposed, introduces realistic diversity that reduces overfitting to fixed patterns and supports the evaluation of detection robustness. This matters because structured CTI alone does not provide the granularity required to express realistic operational diversity.

The gap between descriptive CTI and operational automation also suggests a concrete agenda. One direction is to enrich STIX with optional procedural fields so that the community can share both adversary behavior and the structure required to reproduce it. This need not change the core STIX ontology: optional layers or companion schemas would suffice, and procedural representations such as CACAO playbooks [31] and Attack Flow [6] already illustrate the sequencing and dependency structure missing from current ATT&CK-in-STIX bundles.

A second direction is to use LLMs as an intermediate layer for consolidating heterogeneous reports, extracting implicit preconditions, proposing technique-consistent parameterizations, and generating procedural variants. A third direction is to build standardized datasets that pair narrative descriptions, CTI objects, and executable steps, thereby enabling benchmarking for extraction pipelines, LLM-assisted emulation, and orchestration frameworks.

More broadly, tighter integration among CTI producers, consumers, and emulation platforms is needed if structured intelligence is to support red/blue team preparation, continuous control validation, and threat-informed defense. We therefore read our results as a boundary-mapping study: they quantify what current structured CTI can support and where its limits remain.

In summary, structured CTI provides essential behavioral semantics but lacks the procedural content required for direct automation. Our methodology shows that, with analyst intervention, CTI can support reproducible multi-step enactment experiments and expose exactly where explicit procedure logic must be added in a controlled emulation substrate. For practitioners, this means replacing ad hoc campaign reconstruction with an explicit workflow that separates reusable CTI structure from analyst-supplied procedure logic. More broadly, it clarifies what future machine-actionable CTI would still need to encode.

11 Threats to Validity

Threats to construct validity arise because our measurements reflect the behavioral structure explicitly encoded in STIX objects rather than complete ground-truth campaign procedures. Campaign-technique vectors, sparsity, overlap, and clustering capture only what is documented in structured CTI, rather than complete execution sequences, causal dependencies, or operational context. Likewise, the tactic-ordered lists used in our methodology provide an organizational scaffold and are not intended to reconstruct actual temporal order. As a result, aspects such as failed attempts, branching logic, concurrency, and environment-specific constraints are outside the scope of our analysis.

Threats to internal validity stem primarily from data quality and curation practices. Our manual cross-checks revealed that the downloadable ATT&CK Enterprise STIX bundle can diverge from the website on campaign-group relationships, leading to incomplete or outdated links in the bundle snapshot used for analysis. Public CTI also exhibits curation bias: only a subset of known operations is represented in structured form, and documentation quality varies across campaigns and intrusion sets. We mitigate these risks through deterministic parsing, consistent normalization of objects and relationships, validation of counts and links, and manual cross-checks against the authoritative ATT&CK website.

During emulation, experiments are conducted in an isolated containerized testbed. However, the legacy Docker artifact uses a shared pre-composed substrate and required small runtime repairs on a fresh host: executable bits, minimal Caldera configuration files, host-architecture-aware bootstrap adjustments in our ARM64 reruns, waiting for service-level readiness as campaign bootstrap scripts completed in sequence, and waiting for the Caldera agent to reach a stable trusted state before creating operations. We therefore interpret execution outcomes as evidence of procedural progress and blocking points within that substrate, not as proof of independent per-campaign historical replay.

External validity is limited by both the scope of available CTI and the degree of abstraction in the emulation environment. Our quantitative analysis focuses on the ATT&CK Enterprise dataset and does not cover proprietary sources or other domains such as Mobile or ICS. This focus is a design choice grounded in our exploratory parsing of the public-source corpus, where Enterprise preserved the most campaign-level structure among the public feeds we examined; it should not be read as a universal claim about all possible STIX collections.

The emulation environment is intentionally simplified and designed to test procedural coherence, not to reproduce historical victim infrastructures. Because STIX does not encode preconditions, parameters, privilege requirements, or environment bindings, the translation step necessarily involves explicit human assumptions. Different analysts may therefore derive slightly different, yet behaviorally consistent, executions. The eight-adversary Docker audit broadens the execution evidence within the legacy artifact, but it remains a curated subset of workflows packaged there and should be interpreted as corroborating breadth rather than as a statistically representative sample of all ATT&CK campaigns. These limitations reflect structural properties of current CTI standards and bound the degree of automation achievable with publicly available structured intelligence.

12 Conclusion

This paper turns a familiar intuition into a measured workflow boundary. Public structured CTI tells us which behaviors were involved in a campaign, but not the executable procedure needed to replay them. Our three-stage methodology makes that boundary

operational: Stage 1 extracts a behavioral scaffold, Stage 2 reconstructs the missing procedure, and Stage 3 packages and executes the result on a declared SUT.

The focal case studies and the broader Docker-backed audit show that these translated workflows can make reproducible progress and reach explicit workflow termini on a controlled substrate, but only after explicit parameter binding and environment assumptions. They should not be read as campaign-isolated historical replay.

The practical contribution is therefore not push-button replay. It is a disciplined test of execution readiness: given public structured CTI and a declared SUT, it reveals which workflow elements are already encoded, which still require explicit reconstruction and validation, and where current standards must evolve if machine-actionable multi-step emulation is the goal.

The central takeaway is simple: campaign profiles may be distinctive enough to separate, yet still too incomplete to execute without explicit procedural binding.

Acknowledgments

This work was supported in part by the Coordenação de Aperfeiçoamento de Pessoal de Nível Superior (CAPES), National Council for Scientific and Technological Development (CNPq), and by the Programa de Pós-Graduação em Aplicações Operacionais (PPGAO), Aeronautics Institute of Technology (Instituto Tecnológico de Aeronáutica – ITA). It also received support from the São Paulo Research Foundation (FAPESP), Grants #2020/09850-0 and #2022/00741-0. We thank the C2-DC Laboratory for providing the experimental infrastructure.

References

[1] Abdulellah Alsaheel, Yuhong Nan, Shiqing Ma, Le Yu, Gregory Walkup, Z. Berkay Celik, Xiangyu Zhang, and Dongyan Xu. 2021. ATLAS: A Sequence-based Learning Approach for Attack Investigation. In *Proceedings of the 30th USENIX Security Symposium (USENIX Security '21)*. USENIX Association, Vancouver, BC, Canada, 3005–3022. https://www.usenix.org/conference/usenixsecurity21/presentation/alsaheel

[2] Enes Altinisik, Fatih Deniz, and Hüsrev Taha Sencar. 2023. ProvG-Searcher: A Graph Representation Learning Approach for Efficient Provenance Graph Search. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security* (Copenhagen, Denmark) *(CCS '23)*. Association for Computing Machinery, New York, NY, USA, 2247–2261. doi:10.1145/3576915.3623187

[3] Ahmed Aly, Essam Mansour, and Amr Youssef. 2025. OCR-APT: Reconstructing APT Stories from Audit Logs Using Subgraph Anomaly Detection and LLMs. In *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security (CCS '25)* (Taipei, Taiwan). Association for Computing Machinery, New York, NY, USA, 261–275. doi:10.1145/3719027.3765219

[4] Frederick Barr-Smith, Xabier Ugarte-Pedrero, Mariano Graziano, Riccardo Spolaor, and Ivan Martinovic. 2021. Survivalism: Systematic Analysis of Windows Malware Living-Off-The-Land. In *2021 IEEE Symposium on Security and Privacy (SP)*. IEEE, Los Alamitos, CA, USA, 1557–1574. doi:10.1109/SP40001.2021.00047

[5] Marvin Büchel, Tommaso Paladini, Stefano Longari, Michele Carminati, Stefano Zanero, Hodaya Binyamini, Gal Engelberg, Dan Klein, Giancarlo Guizzardi, Marco Caselli, Andrea Continella, Maarten van Steen, Andreas Peter, and Thijs van Ede. 2025. SoK: Automated TTP Extraction from CTI Reports – Are We There Yet?. In *Proceedings of the 34th USENIX Security Symposium (USENIX Security '25) (SEC '25)*. USENIX Association, Seattle, WA, USA, Article 238, 21 pages.

[6] Center for Threat-Informed Defense. 2025. Attack Flow v3. https://ctid.mitre.org/projects/attack-flow [Online; accessed 2026-03-20].

[7] Yutong Cheng, Osama Bajaber, Saimon Amanuel Tsegai, Dawn Song, and Peng Gao. 2025. CTINexus: Automatic Cyber Threat Intelligence Knowledge Graph Construction Using Large Language Models. In *Proceedings of the 2025 IEEE 10th European Symposium on Security and Privacy (EuroS&P)*. IEEE, Dublin, Ireland, 923–938. doi:10.1109/EuroSP63326.2025.00057

[8] Zijun Cheng, Qiujian Lv, Jinyuan Liang, Yan Wang, Degang Sun, Thomas Pasquier, and Xueyuan Han. 2024. Kairos: Practical Intrusion Detection and Investigation using Whole-system Provenance. In *2024 IEEE Symposium on Security and Privacy (SP)*. IEEE, Los Alamitos, CA, USA, 3533–3551. doi:10.1109/SP54263.2024.00005

[9] ClearSky Cyber Security. 2020. *Fox Kitten: Widespread Iranian Espionage-Offensive Campaign*. Technical Report. ClearSky Cyber Security. https://www.clearskysec.com/wp-content/uploads/2020/02/ClearSky-Fox-Kitten-Campaign.pdf Threat intelligence report.

[10] Suresh K. Damodaran and Paul D. Rowe. 2025. Automated Repeatable Adversary Threat Emulation with Effects Language (EL). arXiv:2510.06420 arXiv:2510.06420.

[11] Sofia Della Penna, Roberto Natella, Vittorio Orbinato, Lorenzo Parracino, and Luciano Pianese. 2025. CTI-HAL: A Human-Annotated Dataset for Cyber Threat Intelligence Analysis. arXiv preprint arXiv:2504.05866. https://arxiv.org/abs/2504.05866 Unpublished.

[12] Gelei Deng, Yi Liu, Víctor Mayoral-Vilches, Peng Liu, Yuekang Li, Yuan Xu, Tianwei Zhang, Yang Liu, Martin Pinzger, and Stefan Rass. 2024. PENTESTGPT: Evaluating and Harnessing Large Language Models for Automated Penetration Testing. In *Proceedings of the 33rd USENIX Security Symposium* (Philadelphia, PA, USA) *(SEC '24)*. USENIX Association, USA, Article 48, 18 pages.

[13] Jiangyi Deng, Xinfeng Li, Yanjiao Chen, Yijie Bai, Haiqin Weng, Yan Liu, Tao Wei, and Wenyuan Xu. 2024. RACONTEUR: A Knowledgeable, Insightful, and Portable LLM-Powered Shell Command Explainer. arXiv preprint arXiv:2409.02074. https://arxiv.org/abs/2409.02074 Unpublished.

[14] Feng Dong, Shaofei Li, Peng Jiang, Ding Li, Haoyu Wang, Liangyi Huang, Xusheng Xiao, Jiedong Chen, Xiapu Luo, Yao Guo, and Xiangqun Chen. 2023. Are we there yet? An Industrial Viewpoint on Provenance-based Endpoint Detection and Response Tools. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security* (Copenhagen, Denmark) *(CCS '23)*. Association for Computing Machinery, New York, NY, USA, 2396–2410. doi:10.1145/3576915.3616580

[15] Feng Dong, Liu Wang, Xu Nie, Fei Shao, Haoyu Wang, Ding Li, Xiapu Luo, and Xusheng Xiao. 2023. DISTDET: A Cost-Effective Distributed Cyber Threat Detection System. In *Proceedings of the 32nd USENIX Security Symposium (USENIX Security '23)*. USENIX Association, Anaheim, CA, USA, 6575–6592. https://www.usenix.org/conference/usenixsecurity23/presentation/dong-feng

[16] FireEye Threat Intelligence. 2019. *Double Dragon: APT41, a Dual Espionage and Cyber Crime Operation*. Technical Report. FireEye. https://cloud.google.com/blog/topics/threat-intelligence/apt41-dual-espionage-and-cyber-crime-operation Threat intelligence report.

[17] Ryan Gabrys, Mark Bilinski, Sunny Fugate, and Daniel Silva. 2024. Using Natural Language Processing Tools to Infer Adversary Techniques and Tactics under the Mitre ATT&CK Framework. In *Proceedings of the 2024 IEEE 14th Annual Computing and Communication Workshop and Conference (CCWC)*. IEEE, Las Vegas, NV, USA, 541–547. doi:10.1109/CCWC60891.2024.10427746

[18] Xueyuan Han, Thomas Pasquier, Adam Bates, James W. Mickens, and Margo I. Seltzer. 2020. UNICORN: Runtime Provenance-Based Detector for Advanced Persistent Threats. arXiv preprint arXiv:2001.01525. https://arxiv.org/abs/2001.01525 Unpublished.

[19] Md Nahid Hossain, Sanaz Sheikhi, and R. Sekar. 2020. Combating Dependence Explosion in Forensic Analysis Using Alternative Tag Propagation Semantics. In *2020 IEEE Symposium on Security and Privacy (SP)*. IEEE, Los Alamitos, CA, USA, 1139–1155. doi:10.1109/SP40000.2020.00064

[20] Zian Jia, Yun Xiong, Yuhong Nan, Yao Zhang, Jinjing Zhao, and Mi Wen. 2024. MAGIC: Detecting Advanced Persistent Threats via Masked Graph Representation Learning. In *33rd USENIX Security Symposium (USENIX Security 24)*. USENIX Association, Philadelphia, PA, USA, 5197–5214. https://www.usenix.org/conference/usenixsecurity24/presentation/jia-zian

[21] Peng Jiang, Ruizhe Huang, Ding Li, Yao Guo, Xiangqun Chen, Jianhai Luan, Yuxin Ren, and Xinwei Hu. 2023. Auditing Frameworks Need Resource Isolation: A Systematic Study on the Super Producer Threat to System Auditing and Its Mitigation. In *Proceedings of the 32nd USENIX Security Symposium (USENIX Security '23)*. USENIX Association, Anaheim, CA, USA, 355–372. https://www.usenix.org/conference/usenixsecurity23/presentation/jiang-peng

[22] Beomjin Jin, Eunsoo Kim, Hyunwoo Lee, Elisa Bertino, Doowon Kim, and Hyoungshick Kim. 2024. Sharing Cyber Threat Intelligence: Does It Really Help?. In *Proceedings of the 31st Annual Network and Distributed System Security Symposium (NDSS)*. Internet Society, San Diego, CA, USA, –.

[23] Joseph Khoury, Đorđe Klisura, Hadi Zanddizari, Gonzalo De La Torre Parra, Peyman Najafirad, and Elias Bou-Harb. 2024. Jbeil: Temporal Graph-Based Inductive Learning to Infer Lateral Movement in Evolving Enterprise Networks. In *Proceedings of the 2024 IEEE Symposium on Security and Privacy (SP)*. IEEE, San Francisco, CA, USA, 3644–3660. doi:10.1109/SP54263.2024.00009

[24] Isaiah J. King and H. Howie Huang. 2023. Euler: Detecting Network Lateral Movement via Scalable Temporal Link Prediction. *ACM Transactions on Privacy and Security* 26, 3, Article 35 (June 2023), 36 pages. doi:10.1145/3588771

[25] Shaofei Li, Feng Dong, Xusheng Xiao, Haoyu Wang, Fei Shao, Jiedong Chen, Yao Guo, Xiangqun Chen, and Ding Li. 2024. NODLINK: An Online System for Fine-Grained APT Attack Detection and Investigation. In *Proceedings of the 31st*

Annual Network and Distributed System Security Symposium (NDSS). Internet Society, San Diego, CA, USA, –. doi:10.14722/ndss.2024.23204 Online; pages not assigned.

[26] Mingqi Lv, Hongzhe Gao, Xuebo Qiu, Tieming Chen, Tiantian Zhu, Jinyin Chen, and Shouling Ji. 2024. TREC: APT Tactic / Technique Recognition via Few-Shot Provenance Subgraph Learning. In *Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security* (Salt Lake City, UT, USA) *(CCS '24)*. Association for Computing Machinery, New York, NY, USA, 139–152. doi:10.1145/3658644.3690221

[27] Mandiant Consulting. 2025. *Google Cloud Security 2025 Report: M-Trends*. Technical Report. Mandiant, Google Cloud Security. https://services.google.com/fh/files/misc/google_cloud_m-trends_2025.pdf Threat intelligence report.

[28] Yuhan Meng, Shaofei Li, Jiaping Gui, Peng Jiang, and Ding Li. 2025. KnowHow: Automatically Applying High-level CTI Knowledge for Interpretable and Accurate Provenance Analysis. arXiv:2509.05698 arXiv:2509.05698.

[29] Sadegh M. Milajerdi, Rigel Gjomemo, Birhanu Eshete, R. Sekar, and V. N. Venkatakrishnan. 2019. HOLMES: Real-Time APT Detection through Correlation of Suspicious Information Flows. In *2019 IEEE Symposium on Security and Privacy (SP)*. IEEE, Los Alamitos, CA, USA, 1137–1152. doi:10.1109/SP.2019.00026

[30] OASIS CTI Technical Committee. 2021. STIX Version 2.1: Committee Specification 02. https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html [Online; accessed 2024-06-01].

[31] OASIS Open. 2023. CACAO Security Playbooks Version 2.0. https://docs.oasis-open.org/cacao/security-playbooks/v2.0/security-playbooks-v2.0.html [Online; accessed 2026-03-20].

[32] Vittorio Orbinato, Marco Carlo Feliciano, Domenico Cotroneo, and Roberto Natella. 2024. Laccolith: Hypervisor-based Adversary Emulation with Anti-detection. *IEEE Transactions on Dependable and Secure Computing* 21, 6 (2024), 5374–5387.

[33] Wei Qiao, Yebo Feng, Teng Li, Zhuo Ma, Yulong Shen, Jianfeng Ma, and Yang Liu. 2025. Slot: Provenance-Driven APT Detection through Graph Reinforcement Learning. In *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security (CCS '25)* (Taipei, Taiwan). Association for Computing Machinery, New York, NY, USA, 963–977. doi:10.1145/3719027.3744788

[34] Aakanksha Saha, Martina Lindorfer, and Juan Caballero. 2026. Kitten or Panda? Measuring the Specificity of Threat Group Behaviors in Public CTI Knowledge Bases. In *Proceedings of the ACM Asia Conference on Computer and Communications Security (ASIA CCS '26)*. ACM, Bangalore, India, 15. doi:10.1145/3779208.3786258

[35] Kiavash Satvat, Rigel Gjomemo, and V. N. Venkatakrishnan. 2021. Extractor: Extracting Attack Behavior from Threat Reports. In *2021 IEEE European Symposium on Security and Privacy (EuroS&P)*. IEEE, Los Alamitos, CA, USA, 598–615. doi:10.1109/EuroSP51992.2021.00046

[36] Xiangmin Shen, Zhenyuan Li, Graham Burleigh, Lingzhi Wang, and Yan Chen. 2024. Decoding the MITRE Engenuity ATT&CK Enterprise Evaluation: An Analysis of EDR Performance in Real-World Environments. In *Proceedings of the 19th ACM Asia Conference on Computer and Communications Security* (Singapore, Singapore) *(ASIA CCS '24)*. Association for Computing Machinery, New York, NY, USA, 96–111. doi:10.1145/3634737.3645012

[37] Xiangmin Shen, Lingzhi Wang, Zhenyuan Li, Yan Chen, Wencheng Zhao, Dawei Sun, Jiashui Wang, and Wei Ruan. 2025. PentestAgent: Incorporating LLM Agents to Automated Penetration Testing. In *Proceedings of the 20th ACM Asia Conference on Computer and Communications Security (ASIA CCS '25)*. Association for Computing Machinery, New York, NY, USA, 375–391. doi:10.1145/3708821.3733882

[38] Brian Singer, Keane Lucas, Lakshmi Adiga, Meghna Jain, Lujo Bauer, and Vyas Sekar. 2025. InCALMO: An Autonomous LLM-assisted System for Red Teaming Multi-Host Networks. arXiv preprint arXiv:2501.16466. https://arxiv.org/abs/2501.16466 Unpublished.

[39] Brian Singer, Yusuf Saquib, Lujo Bauer, and Vyas Sekar. 2025. Perry: A High-level Framework for Accelerating Cyber Deception Experimentation. arXiv preprint arXiv:2506.20770. https://arxiv.org/abs/2506.20770 Unpublished.

[40] Blake E Strom, Andy Applebaum, Doug P Miller, Kathryn C Nickels, Adam G Pennington, and Cody B Thomas. 2018. *MITRE ATT&CK: Design and Philosophy*. Technical Report. The MITRE Corporation, McLean, VA, USA. – pages.

[41] Nan Sun, Ming Ding, Jiaojiao Jiang, Weikang Xu, Xiaoxing Mo, Yonghang Tai, and Jun Zhang. 2023. Cyber Threat Intelligence Mining for Proactive Cybersecurity Defense: A Survey and New Perspectives. *IEEE Communications Surveys & Tutorials* 25, 3 (2023), 1748–1774. doi:10.1109/COMST.2023.3273282

[42] Mati Ur Rehman, Hadi Ahmadi, and Wajih Ul Hassan. 2024. Flash: A Comprehensive Approach to Intrusion Detection via Provenance Graph Representation Learning. In *2024 IEEE Symposium on Security and Privacy (SP)*. IEEE, Los Alamitos, CA, USA, 3552–3570. doi:10.1109/SP54263.2024.00139

[43] Mathew Vermeer, Michel van Eeten, and Carlos Gañán. 2022. Ruling the Rules: Quantifying the Evolution of Rulesets, Alerts and Incidents in Network Intrusion Detection. In *Proceedings of the 2022 ACM on Asia Conference on Computer and Communications Security* (Nagasaki, Japan) *(ASIA CCS '22)*. Association for Computing Machinery, New York, NY, USA, 799–814. doi:10.1145/3488932.3517412

[44] Caio M. C. Viana, Carlos H. G. Ferreira, Fabricio Murai, Aldri Luiz Dos Santos, and Lourenço Alves Pereira Júnior. 2024. Devil in the Noise: Detecting Advanced Persistent Threats with Backbone Extraction. In *2024 IEEE Symposium on Computers and Communications (ISCC)*. IEEE, Los Alamitos, CA, USA, 1–7. doi:10.1109/ISCC61673.2024.10733665

[45] Apurva Virkud, Muhammad Adil Inam, Andy Riddle, Jason Liu, Gang Wang, and Adam Bates. 2024. How Does Endpoint Detection Use the MITRE ATT&CK Framework?. In *33rd USENIX Security Symposium (USENIX Security 24)*. USENIX Association, Philadelphia, PA, 3891–3908. https://www.usenix.org/conference/usenixsecurity24/presentation/virkud

[46] Jian Wang, Tiantian Zhu, Chunlin Xiong, and Yan Chen. 2024. MultiKG: Multi-source Threat Intelligence Aggregation for High-quality Knowledge Graph Representation of Attack Techniques. arXiv:2411.08359 arXiv:2411.08359.

[47] Lingzhi Wang, Zhenyuan Li, Yi Jiang, Zhengkai Wang, Zonghan Guo, Jiahui Wang, Yangyang Wei, Xiangmin Shen, Wei Ruan, and Yan Chen. 2024. From Sands to Mansions: Towards Automated Cyberattack Emulation with Classical Planning and Large Language Models. arXiv:2407.16928 arXiv:2407.16928.

[48] Ming Xu, Hongtai Wang, Jiahao Liu, Yun Lin, Chenyang Xu, Yingshi Liu, Hoon Wei Lim, and Jin Song Dong. 2024. IntelEX: A LLM-driven Attack-level Threat Intelligence Extraction Framework. arXiv preprint arXiv:2412.10872. https://arxiv.org/abs/2412.10872 Unpublished.

[49] Fan Yang, Jiacen Xu, Chunlin Xiong, Zhou Li, and Kehuan Zhang. 2023. PROGRAPHER: An Anomaly Detection System Based on Provenance Graph Embedding. In *Proceedings of the 32nd USENIX Security Symposium (USENIX Security '23)*. USENIX Association, Anaheim, CA, USA, 4355–4372. https://www.usenix.org/conference/usenixsecurity23/presentation/yang-fan

[50] Le Yu, Shiqing Ma, Zhuo Zhang, Guanhong Tao, Xiangyu Zhang, Dongyan Xu, Vincent E. Urias, Han Wei Lin, Gabriela F. Ciocarlie, Vinod Yegneswaran, et al. 2021. ALchemist: Fusing Application and Audit Logs for Precise Attack Provenance without Instrumentation. In *Proceedings of the Network and Distributed System Security Symposium (NDSS)*. Internet Society, San Diego, CA, USA, –.

[51] Bo Zhang, Yansong Gao, Changlong Yu, Boyu Kuang, Zhi Zhang, Hyoungshick Kim, and Anmin Fu. 2025. TAPAS: An Efficient Online APT Detection with Task-guided Process Provenance Graph Segmentation and Analysis. In *Proceedings of the 34th USENIX Security Symposium (USENIX Security '25)*. USENIX Association, Seattle, WA, USA, 607–624.

A Open Science

The camera-ready artifact for this paper is published at https://github.com/sidneibarbieri/sticks-docker. The repository root contains a reviewer-facing wrapper, `run_review_check.sh`, that reruns the structural measurements, refreshes the frozen Docker-audit summaries, rebuilds the manuscript, and executes the measurement test suite from a clean disposable runtime context.

The same repository also includes an optional end-to-end replay path, `sticks-docker/measurement/run_full_docker_audit.sh`, which reconstructs the shared-substrate Docker lab and reruns the eight curated adversaries packaged in the legacy artifact. We keep that path explicitly labeled as a shared-substrate execution audit rather than campaign-isolated historical replay, consistent with the claims made in Sections 8 and 10.

B Ethical Considerations

This paper studies the procedural boundary between public structured CTI and executable adversary emulation. Its contribution is measurement, translation discipline, and reproducibility guidance rather than a new offensive capability. The released artifact operates on public ATT&CK-style CTI plus a frozen local laboratory substrate and is intended to show where analyst-supplied procedure remains necessary.

The main dual-use concern is that executable traces in the legacy Docker audit could be mistaken for turnkey replay of historical intrusions. We mitigate that risk by keeping the artifact's claims narrow, documenting the shared-substrate nature of

the Docker audit, and separating frozen audit evidence from the analyst-supervised translation work required to derive procedures from CTI.

C Generative AI Usage

Generative AI tools were used during manuscript editing and artifact-maintenance work. They assisted with rewriting dense prose, proposing structural edits, and refactoring support scripts and checks. The authors reviewed all AI-assisted text and code, reran the measurement and manuscript pipelines after each substantive change, and manually verified that reported values, tables, figures, and claims remained grounded in the source datasets and released artifact.

D Automation-Relevant Field Population

Table 3 summarizes the structured-field audit over the 691 active Enterprise attack-patterns used in this study. The pattern is consistent with the automation boundary discussed in Section 10: Stage 1 fields are populated, while the candidate Stage 2 fields are absent or empty in the current export.

Table 3: Population of automation-relevant fields across the active Enterprise attack-patterns.

Field	Present	Non-empty
`kill_chain_phases`	691	691
`x_mitre_platforms`	691	691
`x_mitre_system_requirements`	0	0
`x_mitre_detection`	691	0
`x_mitre_data_sources`	0	0
`x_mitre_permissions_required`	0	0

E Supplementary Set-Based Reuse Probe

To complement the tactic-ordered LCS analysis with an order-free probe, we compute for each itemset size $k \in \{1, \ldots, 5\}$ the maximum support of any k-technique itemset across the 51 Enterprise campaigns. The rapid decay in Table 4 reinforces the same conclusion as the clustering and LCS results: campaigns share small recurring fragments, but not a dominant reusable backbone.

Table 4: Maximum support of any unordered technique itemset across the 51 Enterprise campaigns.

Itemset size	Max support	Campaign share
1	28	54.9%
2	17	33.3%
3	10	19.6%
4	7	13.7%
5	6	11.8%